

DOCKER

Modül 17.8.3

Capabilities ve Seccomp

Kernel yetkilerini mikro seviyede kısıtlama

Data Science RoadMap

Alican Kaya

github.com/AlicanKaya192

Linux Capabilities Nedir?

Geleneksel Linux'ta ya tam yetkili (root) ya da yetkisiz kullanıcı vardır. Linux Capabilities (Yetenekler), root'un devasa yetkilerini 40'a yakın küçük parçaya böler (örn: sadece ağ kartı ayarlama, sadece saati değiştirme, sadece 80 portunu açma gibi).

Docker'da Yetki Düşürme (Drop Capabilities)

Docker varsayılan olarak bazı yetkileri engellese de, çoğu web uygulaması için bu bile fazladır. Güvenli yöntem: TÜM yetkileri iptal edip (--cap-drop=ALL), SADECE gerekenleri (--cap-add) açmaktır.

```
bash

# İyi Güvenlik Uygulaması:
docker run -d \
  --cap-drop=ALL \
  --cap-add=NET_BIND_SERVICE \
  my_web_server

# KESİNLİKLE KULLANILMAMASI GEREKEN KOMUT:
docker run --privileged # Tüm izolasyonu kaldırır, host'a tam erişim verir!
```

Seccomp (Secure Computing)

Seccomp, konteyner içindeki bir yazılımın Linux Kernel'ine hangi 'Sistem Çağrılarını' (System Calls) yapabileceğini sınırlar. Docker, varsayılan olarak 300'den fazla sistem çağrısından yaklaşık 44 tehlikeli olanı (örn: reboot, kernel modülü yükleme) bloklayan default bir profil ile gelir.

Read-Only Root Filesystem

Bir konteyner hacklendiğinde saldırgan genellikle sisteme zararlılar (malware, miner) indirmeye çalışır. Eğer konteynerin dosya sistemini salt-okunur yaparsanız bu işlem başarısız olur.

```
bash

docker run -d \
  --read-only \
  -v /app/tmp_data:/tmp \
  my_app
```

[i] NOT

--read-only kullanırken uygulamanın /tmp veya log klasörlerine yazı yazması gerekiyorsa, bu klasörleri ya Volume/Bind Mount olarak bağlamalı ya da tmpfs (RAM disk) olarak tanımlamalısınız.